

LLD-SEC-001 SECURITY & IDENTITY

Low Level Design — Security & Identity

LLD	SEC-001	v1.0	ZERO TRUST	CONFIDENTIAL
-----	---------	------	------------	--------------

IAM | GuardDuty | Security Hub | KMS | ITAR | NIST 800-53
SpaceNet-IT | HLD Ref: SPACENET-HLD-001 | June 2026

1. Scope & Purpose

This LLD defines the detailed security and identity architecture for the AWS Ground Station solution. It covers IAM Identity Center configuration, role-based access control, network security, encryption, threat detection, incident response automation, and ITAR/NIST 800-53 compliance controls across all accounts and services.

2. Identity & Access Management

2.1 IAM Identity Center (SSO)

Identity source	Corporate IdP (Okta / Azure AD) via SAML 2.0 federation
MFA	TOTP (Authenticator app) enforced for all users — hardware FIDO2 for privileged
Session duration	8 hours standard / 1 hour for privileged roles (re-auth required)
Permission sets	Defined per role — propagated to all target accounts automatically
Break glass	2 IAM users — no SSO, local credentials, CloudTrail alert on use
Access reviews	Quarterly — IAM Access Analyzer generates access review reports

2.2 Permission Set Design (Least Privilege)

FlightOps-ReadOnly	fleet-mgmt, noc-ops	Grafana, TwinMaker, DynamoDB:GetItem	no write, no TC submission
FlightOps-Operator	fleet-mgmt, noc-ops	API Gateway:Invoke (TC submit), Grafana	no submit — dual approval required
GroundOps-Operator	ground-segment	Ground Station:*, ECS:Describe, CloudWatch	no ECS Stop without approval
DataEngineer	mission-data	Timestream:Read, S3:GetObject, OpenSearch:DescribeIndex	no S3 Delete, no PutObjectLegalHold
PlatformEngineer	All accounts	EKS:*, EC2:*, Terraform state buckets	no IAM role creation without PR review
SecurityAnalyst	security-prod	GuardDuty:*, SecurityHub:*, CloudTrail:Describe	no delete — no config changes
AccountAdmin	All	All (break-glass equivalent)	PIM — JIT 4h max, approval required

2.3 Service Control Policies (SCPs)

DenyPublicS3	All mission OUs	s3:PutBucketPublicAccessBlock(false), s3:PutBucketACL(public)
DenyUnencryptedStorage	All mission OUs	s3:PutObject without SSE-KMS, dynamodb:CreateTable without encryption
DenyPublicEndpoints	All mission OUs	rds:CreateDBInstance(PubliclyAccessible=true), es:CreateDomain(public)
EnforceRegions	Mission Workloads	All services except in ap-southeast-2 and us-east-1

DenyRootUser	All accounts	All actions when aws:PrincipalIsAWSService=false and username=root
DenyKMSKeyDelete	All mission OUs	kms:ScheduleKeyDeletion without approval tag
ITARDataResidency	Mission Workloads	s3:PutObject to buckets outside AU/US regions for ITAR-tagged objects

3. Network Security

3.1 VPC Architecture

ground-segment-prod	10.10.0.0/20	3 private subnets (AZ a/b/c) — no public subnets	None — Direct Connect only
fleet-mgmt-prod	10.20.0.0/20	3 private subnets — EKS node groups	NAT Gateway (egress only) via Firewall
mission-data-prod	10.30.0.0/20	3 private subnets — data services only	None — VPC Endpoints only
noc-ops-prod	10.40.0.0/20	3 private + 3 protected subnets — ALB in protected	AWS WAF — operator IPs only
security-prod	10.50.0.0/20	3 private subnets — security tooling	NAT Gateway (Firewall egress)

3.2 AWS Network Firewall Rules

Allow-Ground-Station-UDP	Inbound ground-segment VPC	Allow	UDP/55888 from AWS Ground Station service CIDR
Allow-HTTPS-Egress	Outbound all VPCs	Allow	443/TCP to AWS service endpoints (VPC Endpoint preferred)
Allow-DirectConnect	Inbound ground-segment VPC	Allow	All from Direct Connect BGP peer IP
Deny-All-Other-Inbound	Inbound all VPCs	Drop + Log	Everything not explicitly allowed
Allow-NTP	Outbound all VPCs	Allow	UDP/123 to Amazon Time Sync Service (169.254.169.123)
Block-ITAR-Countries	Outbound noc-ops VPC	Reject	IP ranges for ITAR-restricted countries (OFAC list)
IDS-Stateful	All directions	Alert + Drop	Suricata rules — known satellite attack patterns

3.3 VPC Endpoints (Private Access)

S3	Gateway endpoint	All accounts
DynamoDB	Gateway endpoint	All accounts
Kinesis Data Streams	Interface endpoint	fleet-mgmt, ground-segment
KMS	Interface endpoint	All accounts
ECR API + DKR	Interface endpoint	fleet-mgmt, ground-segment

ECS + Fargate	Interface endpoint	ground-segment
Secrets Manager	Interface endpoint	All accounts
Ground Station	Interface endpoint	ground-segment
SSM + SSM Messages	Interface endpoint	All accounts
CloudWatch Logs	Interface endpoint	All accounts

4. Encryption

4.1 KMS Key Architecture

alias/spacenet-s3-frames	KMS CMK (Symmetric)	mission-data	S3 raw-frames bucket — ITAR controlled
alias/spacenet-kinesis	KMS CMK (Symmetric)	fleet-mgmt	Kinesis Data Streams (all 4 streams)
alias/spacenet-dynamodb	KMS CMK (Symmetric)	mission-data	All DynamoDB tables
alias/spacenet-timestream	KMS CMK (Symmetric)	mission-data	Timestream database
alias/spacenet-opensearch	KMS CMK (Symmetric)	mission-data	OpenSearch domain
alias/spacenet-rds	KMS CMK (Symmetric)	mission-data	Aurora PostgreSQL cluster
alias/spacenet-command-signing	KMS Asymmetric (RSA-4096)	fleet-mgmt	TC command signing — private key never exported
alias/spacenet-secrets	KMS CMK (Symmetric)	All	Secrets Manager secrets

4.2 TLS Enforcement

API Gateway (operator APIs)	TLS 1.2	TLS_1_2 policy	ACM — public cert
ALB (NOC dashboards)	TLS 1.2	ELBSecurityPolicy-TLS13-1-2	ACM — public cert
IoT Core (MQTT)	TLS 1.2	IoTSecurityPolicy-TLS13	IoT Core CA — device cert per satellite
EKS API server	TLS 1.2	Cluster default	ACM Private CA
App Mesh service-to-service	TLS 1.3	mTLS enforced	ACM Private CA — auto-rotated
OpenSearch	TLS 1.2	HTTPS only	ACM Private CA
RDS Aurora	TLS 1.2	rds.force_ssl=1	ACM Private CA

5. Threat Detection & SIEM

5.1 Amazon GuardDuty

Enabled accounts	All accounts — delegated admin in security-prod
S3 Protection	Enabled — unusual data access patterns on raw-frames bucket
EKS Protection	Enabled — runtime threat detection on fleet-mgmt EKS cluster
Malware Protection	Enabled — EBS volume scan on threat finding
RDS Protection	Enabled — anomalous Aurora login detection
Lambda Protection	Enabled — Lambda network activity monitoring
Custom threat intel	S3 bucket with satellite operator IOC feeds (IP, domain blocklists)
Findings export	EventBridge → Security Hub → OpenSearch Security Analytics

5.2 AWS Security Hub

AWS Foundational Security Best Practices	All 295 controls	95%+
CIS AWS Foundations Benchmark v1.4	All 58 controls	90%+
NIST SP 800-53 Rev 5	All controls	85%+
PCI DSS v3.2.1 (for comms billing)	Applicable subset	N/A — informational

5.3 Automated Incident Response (EventBridge + Lambda)

GuardDuty: UnauthorizedAccess:IAMUser	LOW	Disable IAM user, revoke sessions, alert SOC	SOC investigates within 15min
GuardDuty: Backdoor:EC2/XORDDOS	CRITICAL	Isolate EC2 (remove from SG), snapshot EBS	SOC forensics within 30min
Anomalous TC submission (off-hours)	HIGH	Hold TC queue, alert NOC security lead	Operator re-authenticates + approves
S3 GetObject from non-approved IP	MEDIUM	CloudWatch alarm, Macie alert	Security analyst reviews within 1hr
Root user login detected	CRITICAL	SNS to all admins, CloudTrail snapshot	Immediate SOC investigation
KMS key usage from unknown principal	HIGH	CloudWatch alarm, GuardDuty finding	Security analyst reviews within 1hr
EKS anomalous exec/attach to pod	HIGH	Network policy isolate pod, alert SOC	SOC investigates within 15min

6. ITAR / EAR Compliance Controls

Data residency	SCP DenyOutsideRegions on all ITAR data accounts	AWS Config rule: s3-bucket-in-approved-region

Access control	IAM Identity Center: US-person attribute assertion from QuaddP	Quarterly access review + IdP audit
Data classification	Amazon Macie: custom data identifiers for ITAR key words in S3	Weekly scheduled scan — weekly
Encryption	All ITAR data encrypted with KMS CMK — key policy CloudTrail on OS key principals	CloudTrail on OS key principals
Audit trail	CloudTrail (all regions, all accounts) → S3 Object Lock (Compliance mode) enabled	CloudTrail on OS key principals
Export screening	S3 bucket policies deny PutObject from non-approved IAM Access Analyzer external access findings	IAM Access Analyzer external access findings
Contractor access	Temporary IAM Identity Center accounts with 90-day expiry Review restrictive permission sets	Access Review restrictive permission sets
GovCloud boundary	ITAR-classified command data isolated in us-gov-west-1 security boundary (no sign-off)	Architecture diagram (for sign-off)

7. NIST 800-53 Control Mapping

AC — Access Control	AC-2, AC-3, AC-6, AC-17	IAM Identity Center, Permission Sets, SCPs, PrivateLink
AU — Audit & Accountability	AU-2, AU-3, AU-9, AU-12	CloudTrail (all accounts), S3 Object Lock, VPC Flow Logs
CA — Assessment	CA-7	Security Hub continuous assessment, quarterly pen test
CM — Config Management	CM-2, CM-6, CM-8	AWS Config, Terraform IaC, Systems Manager Inventory
IA — Identification	IA-2, IA-5, IA-8	IAM Identity Center, MFA, Secrets Manager
IR — Incident Response	IR-4, IR-5, IR-8	EventBridge SOAR, Lambda automation, NOC runbooks
SC — System & Comms	SC-7, SC-8, SC-12, SC-28	VPC, NACLs, TLS, KMS, Network Firewall
SI — System Integrity	SI-2, SI-3, SI-4	Inspector, GuardDuty, ECR scanning, ADOT observability

8. Security Monitoring Metrics & Alerting

Failed API auth attempts	CloudTrail → CloudWatch Metric Filter per user	15 min 5 filter per user	Lock user, alert SOC
GuardDuty HIGH findings	Security Hub EventBridge	Any HIGH/CRITICAL	Page SOC on-call immediately
Root user activity	CloudTrail root API filter	Any	Critical page — all admins
S3 ITAR bucket public access	Config rule	Any change	Auto-remediate + alert
KMS key rotation overdue	Config rule	Key > 365 days	Alert platform engineer
Unpatched EKS nodes	Inspector finding	CRITICAL CVE	EKS managed node group rolling update
MFA not enrolled	IAM Access Analyzer	Any user > 24h	Disable user, alert manager

Anomalous S3 data egress	Macie + GuardDuty	Any finding	Alert security analyst + block IP